

Retrieve, Reproduce, Reveal: Dissecting Retrieval-Augmented Software Vulnerability Detection

SABRINA KANIEWSKI[✉], Institute for Secure Networked Systems, Esslingen University, Germany

TIM KRÄMER, Esslingen University, Germany

JULIUS BÄCHLE, Institute for Intelligent Systems, Esslingen University, Germany

MARKUS ENZWEILER, Institute for Intelligent Systems, Esslingen University, Germany

MICHAEL MENTH, Chair of Communication Networks, University of Tübingen, Germany

TOBIAS HEER, Institute for Secure Networked Systems, Esslingen University, Germany

Retrieval-Augmented Generation (RAG) is increasingly used to enhance Large Language Model (LLM)-based software vulnerability detection by grounding predictions in retrieved vulnerability knowledge, such as vulnerability reports. However, existing RAG-based software vulnerability detection (RAG4SVD) systems are often evaluated using proprietary models, which challenges open science and reproducibility. Further, studies use different datasets, custom knowledge bases, different backbone models, and diverse metrics, which hinders meaningful cross-system comparison. In this work, we study six open-source RAG4SVD systems and address these reproducibility and comparability challenges through (i) reproduction of their experimental settings under an open-weight setting, and (ii) a unified benchmark using a common dataset, metric suite, and pool of open-weight models. Further, RAG4SVD systems typically consist of multiple components, yet are often evaluated only as a whole system, i.e., end-to-end. Therefore, we perform (iii) a component-level analysis that decomposes representative RAG4SVD pipelines into input abstraction, knowledge retrieval, and detection. Our results demonstrate that reproducibility varies substantially across systems. Under the presented unified benchmark, published RAG4SVD performance does not transfer under a controlled open-weight evaluation and depends strongly on the used model. The component analysis shows that effective RAG4SVD depends on the alignment between pipeline stages. For example, oracle knowledge raises retrieval to near-optimal, yet performance remains low (0.51 pairwise accuracy), demonstrating that retrieval effectiveness alone is insufficient for reliable detection. These findings motivate evaluating RAG4SVD not only end-to-end, but at the level of pipeline components, and provide a basis for more standardized, RAG-aware evaluation practices.

Additional Key Words and Phrases: software vulnerability detection, software security, retrieval-augmented generation, large language models, reproducibility, benchmark

1 Introduction

Large language models (LLMs) are increasingly applied to software vulnerability detection by leveraging their code-understanding and reasoning capabilities to discover insecure code [17]. However, an LLM’s internal knowledge is inherently limited by its training data and respective cutoff date. Thus, newly disclosed vulnerabilities, emerging attack patterns, and project-specific security knowledge that were published after the training cutoff date may be unavailable to the model at inference time. Retrieval-Augmented Generation (RAG) [20] addresses this limitation by dynamically retrieving external vulnerability knowledge, e.g., Common Weakness Enumeration (CWE) descriptions, specific Common Vulnerabilities and Exposures (CVE) reports, or similar vulnerable code examples, from a knowledge base and incorporating it into the prompt [3]. Unlike costly retraining or fine-tuning, the knowledge base can be updated independently of the model to add more specific and up-to-date information and, thus, enhance detection performance.

The adoption of RAG for LLM-based software vulnerability detection (RAG4SVD) has grown rapidly, with proposed RAG systems reporting improvements over non-retrieval baselines [3, 8, 17]. RAG4SVD systems typically follow a common pipeline, cf. Fig. 1: The code under analysis is first transformed via *input abstraction* into the representation used to query the knowledge base, e.g., the raw code itself or a semantic summary of the code. This query is passed to a *knowledge retrieval*

mechanism, e.g., based on embedding similarity, lexical matching, structured lookup, or a hybrid combination thereof, which retrieves relevant entries. Finally, the retrieved knowledge is combined with the code under analysis and passed to the LLM for *detection*, producing a vulnerability prediction, e.g., a binary vulnerable/non-vulnerable label.

Yet, it remains unclear how generalizable reported gains are. First, results are rarely independently verified [18]. Incomplete public artifacts, undocumented preprocessing and dependencies, non-deterministic inference, and reliance on proprietary models or APIs further complicate reproducing LLM-based systems [14, 18, 33]. Model providers may discontinue or modify their models without notice, which renders experiments non-reproducible. Second, systems differ substantially in their datasets, knowledge bases, query representations, retrieval mechanisms, and backbone models [3, 17]. Consequently, results across individual studies do not provide a basis for comparing different systems. Third, despite the fact that these systems consist of multiple components, they are commonly evaluated only through their final detection accuracy, i.e., end-to-end. It is often unclear if improvements stem from the quality and coverage of the knowledge base, the abstraction used to formulate a retrieval query, the retrieval mechanism, or the capabilities of the detection model used. We summarize these observations as three evaluation gaps in the current literature:

Reproducibility Gap: The results of published RAG4SVD systems have rarely been independently reproduced. It remains uncertain whether reported performance can be recovered.

Comparability Gap: Systems are evaluated using different datasets, custom knowledge bases, different models, and diverse metrics, preventing meaningful cross-system comparison.

Attribution Gap: RAG systems are predominantly evaluated end-to-end; consequently, it remains unclear which pipeline components drive observed performance improvements.

To address these gaps, we present, to the best of our knowledge, the first study in RAG-based software vulnerability detection to jointly assess reproducibility, cross-system performance, and individual pipeline components. The **contributions** of this work are threefold: (i) Considering six open-source RAG4SVD systems, i.e., *SVD-Bench* [45], *Llama-VD*¹ [27], *GRACE* [22], *LLM4Vuln* [37],

¹We introduce the abbreviation *Llama-VD* in this work for brevity.

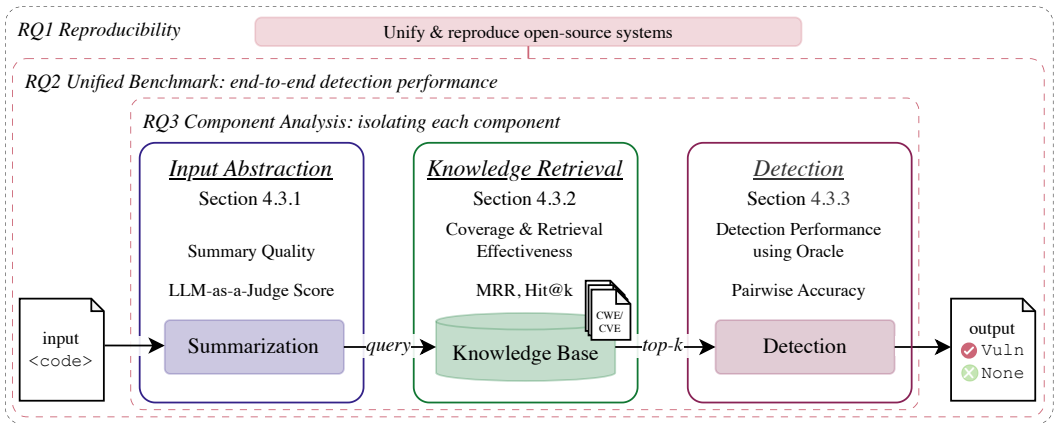


Fig. 1. Overview of a typical RAG4SVD pipeline and the evaluation roadmap of this work.

Vul-RAG [8], and *VulTriage* [39], we first reproduce systems using open-weight models and quantify deviations from their reported results. (ii) Second, we analyze how the considered RAG4SVD systems compare when re-implemented under a common dataset, metric suite, and pool of heterogeneous open-weight models, enabling controlled comparison across independently proposed systems. (iii) Third, we move beyond end-to-end evaluation and dissect representative multi-stage RAG4SVD pipelines into *input abstraction*, *knowledge retrieval*, and *detection*, proposing a component-aware evaluation of RAG4SVD systems. Specifically, we evaluate whether generated abstractions preserve information useful for retrieval, whether relevant knowledge is actually retrieved, and whether oracle knowledge improves the detection performance. Together, these analyses provide a RAG-aware evaluation that examines not *whether* RAG improves vulnerability detection, but *which* components drive performance. The replication package for this study is publicly available at <https://github.com/hs-esslingen-it-security/RAG4SVD>.

The remainder of this work is structured as follows. Section 2 reviews related work. Section 3 describes the experimental setup, i.e., the selection of RAG4SVD systems, datasets, metrics, models, and implementation details. Section 4 presents the evaluation along the identified gaps and discusses the findings. We address threats to validity in Sect. 5 and conclude this work in Sect. 6.

2 Related Work

Research on LLM-based software vulnerability detection has expanded rapidly in recent years [17]. In this section, we review prior work on (i) benchmarking LLM-based software vulnerability detection, (ii) benchmarking RAG-based software vulnerability detection approaches, and (iii) component-level evaluation of RAG pipelines, positioning the contributions of this work.

2.1 Benchmarking LLM-based Vulnerability Detection

Several works benchmark how different prompting and tuning strategies affect vulnerability detection performance [35, 38, 41, 45]. For example, Steenhoek et al. [35] systematically compare prompting strategies, including in-context learning, few-shot, and Chain-of-Thought prompting, and Zhang et al. [45] compare prompt engineering, instruction tuning, and sequence-classification fine-tuning across programming languages and model sizes. However, none of these efforts extend to different RAG-based systems, which introduce an additional layer of design choices, such as knowledge base construction or retrieval strategy, on top of existing evaluation challenges.

Recent works further question whether reported performance reflects genuine detection capability of LLMs or is instead an artifact of the datasets and evaluation protocols used [7, 35, 41]. Ding et al. [7] show that established benchmarks such as BigVul [10] overestimate model performance due to, e.g., noisy labels and high duplication rates [13]. To address these issues, they introduce an improved vulnerability dataset *PrimeVul*, which combines rigorous de-duplication and human-verified labeling with a stricter pairwise evaluation protocol. Under this more realistic setting, reported F1 scores for state-of-the-art code language models dropped to as low as 0.03, motivating a shift toward *PrimeVul* as the de facto benchmark for LLM-based software vulnerability detection, which we also adopt as a common benchmark dataset. Further, we assess multiple detection models across systems, allowing us to distinguish gains attributable to model capacity from gains attributable to the RAG system architectures. In doing so, we extend prior LLM benchmarking from model-centric evaluation to system-level evaluation of RAG-based vulnerability detection.

2.2 Fragmented Evaluation of Retrieval-Augmented Vulnerability Detection

Existing RAG-based software vulnerability detection systems are predominantly evaluated in isolation, often using custom evaluation protocols, making direct comparisons difficult [17].

Kaniewski et al. [18] provide an initial reproducibility and replicability study of Vul-RAG [8]. Motivated by the dependence of many LLM-based approaches on proprietary models, the authors adapt the Vul-RAG pipeline to an open-weight setting and first reproduce its reported open-weight baselines before evaluating a broader set of LLMs. However, the study scope is intentionally restricted to a single RAG4SVD system and primarily investigates reproducibility and model replicability; it does not compare multiple proposed RAG architectures, transfer them to a new dataset, or evaluate individual pipeline components.

Where multi-system comparisons do exist, they are scoped differently: For example, VulInstruct [47] and RASM-Vul [46] each compare their detection performance only against Vul-RAG [8]; and VulTriage [39] ablates pipeline components to quantify their individual contribution. However, comparisons via final detection performance and ablations do not reveal which RAG design choices generalize, nor whether reported gains reproduce outside their evaluation setting.

This fragmentation is further highlighted by Chen et al. [3]. Surveying 30 RAG-based studies across the software vulnerability lifecycle, they highlight that evaluation practices remain fragmented across datasets, baselines, models, and metrics. We address this gap: to the best of our knowledge, we present the first reproducibility assessment and benchmark for RAG4SVD, applying a common dataset, metric suite, and model pool across systems to make reported gains comparable.

2.3 RAG Evaluation Methodology and Component Analysis

RAG evaluation frameworks such as RAGAs [9] and ARES [32] automate faithfulness and relevance scoring via an LLM-as-a-Judge. However, these frameworks assume free-text question-answer tasks and do not address the semantics of software vulnerability detection, where retrieval is based on input code and retrieved artifacts consist of code fragments or structured vulnerability knowledge. For the software vulnerability lifecycle, Chen et al. [3] further highlight that RAG-specific properties such as retrieval quality, grounding, and faithfulness remain insufficiently evaluated.

Component-wise evaluation of RAG pipelines has been explored for selected software engineering tasks. Ke et al. [19] present a component-wise empirical study that systematically isolates and evaluates four query processing techniques, seven retrieval models, four context refinement methods, and six generators across the code generation, summarization, and repair tasks. However, their evaluation focuses on extrinsic performance: every component is judged solely by its effect on final task performance, but never assessed individually (e.g., whether retrieved knowledge is relevant). We address this gap by expanding *extrinsic* evaluation with *intrinsic* evaluation. Rather than varying components across systems, we evaluate the components of representative RAG4SVD systems in isolation alongside standard detection metrics.

3 Experimental Setup

Our experimental design is built around the three evaluation gaps identified in Sect. 1 and visualized in Fig. 1. To address the *Reproducibility Gap*, we first reproduce considered open-weight systems and assess whether their reported results can be recovered (**RQ1**). To address the *Comparability Gap*, we evaluate the systems using a common dataset, metric suite, and open-weight model pool, enabling a controlled comparison of their performance (**RQ2**). Finally, to address the *Attribution Gap*, we dissect representative RAG4SVD pipelines into input abstraction, knowledge retrieval, and detection, and evaluate these components individually to determine how they contribute to overall performance (**RQ3**). Accordingly, we formulate the following research questions:

- RQ1** To what extent are published open-source RAG4SVD systems reproducible?
- RQ2** How do open-source RAG4SVD systems compare under a unified benchmark?
- RQ3** Which component-level factors drive detection in representative RAG4SVD pipelines?

3.1 RAG4SVD System Selection

We consider RAG as the dynamic selection of external context at inference-time, conditioned on the code under analysis. Within RAG4SVD, we consider *example-retrieval* RAG, where semantically or lexically similar labeled code examples are selected for few-shot prompting, and *knowledge-retrieval* RAG, where the system queries a dedicated vulnerability knowledge base.

A continuously updated survey artifact by Kaniewski et al. [14] tracks LLM-based software vulnerability detection literature. As of August 2026, it lists 31 studies implementing RAG within the RAG4SVD scope. For this study, we require (i) publicly accessible implementation code or equivalent executable artifacts and (ii) a sufficiently complete and documented setup to reconstruct the RAG pipeline and its evaluation, including the required data, configuration, and reported experimental settings. Applying these criteria leaves 12 (39%) studies with public artifacts, of which only 6 provide a complete and executable setup for reproduction. Fig. 2 summarizes the selection process. We provide study-specific inclusion and exclusion rationale in the replication package. Tab. 1 summarizes the selected systems along the RAG4SVD pipeline stages.

SVD-Bench [45] studies RAG as one of several prompting techniques. It uses dense retrieval, which embeds the function under analysis and labeled training functions with the `simcse-bert`-base model and ranks them by cosine similarity to retrieve the top- n most similar examples.

Llama-VD [27] investigates different prompting and fine-tuning strategies for adapting Llama-3.1-8B to vulnerability detection. It applies dense retrieval using `codebert`-base, and the 6 nearest training examples are retrieved using Euclidean distance. The study additionally explores using RAG-selected examples in test-time tuning, thereby combining retrieval with parameter adaptation.

GRACE [22] uses dense retrieval, embedding the function under analysis and training functions with `CodeT5` to retrieve semantically similar candidates. These candidates are subsequently re-ranked using lexical token overlap and syntactic similarity derived from Abstract Syntax Tree (AST) representations to select a single example. *GRACE* further extracts structural program information from the code and supplies it alongside the code and retrieved example in the prompt.

LLM4Vuln [37] presents a modular evaluation framework that separates an LLM’s intrinsic vulnerability reasoning from external enhancements, including knowledge retrieval, program-context supplementation, and prompting. For knowledge retrieval, it uses dense retrieval with `text-embedding-ada-002`, supporting either the raw source code or an LLM-generated functionality summary (semantic abstraction) as the query representation. The top-3 most similar entries are

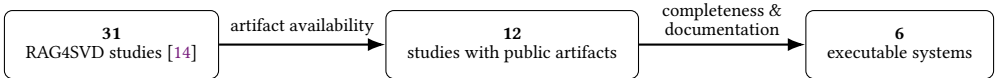


Fig. 2. RAG4SVD system screening and selection.

Table 1. Overview of representative RAG4SVD systems considered in this study, characterized by their retrieval query, retrieval mechanism, retrieved knowledge, and coverage in the research questions RQ1–RQ3.

System	Query	Retrieval	Retrieved Knowledge	RQ1	RQ2	RQ3
SVD-Bench [45]	Code	Dense (<code>simcse-bert</code> -base)	Code examples	✓	✓	
Llama-VD [27]	Code	Dense (<code>codebert</code> -base)	Code examples	✓	✓	
GRACE [22]	Code	Dense (<code>CodeT5</code>) + re-ranking	Code examples		✓	
LLM4Vuln [37]	Semantic abstr.	Dense (<code>text-embedding-ada-002</code>)	Summarized CWE reports	✓		✓
Vul-RAG [8]	Code + semantic abstr.	Sparse (<code>BM25</code>) + re-ranking	Functionality + root causes + patches	✓	✓	✓
VulTriage [39]	Vulnerability abstr.	Hybrid (dense + sparse; <code>bge-m3</code>)	CWE descriptions + code examples		✓	

retrieved, and their associated raw or summarized vulnerability knowledge, including vulnerability descriptions and root causes, is supplied to the LLM for detection.

Vul-RAG [8] retrieves abstract, vulnerability-specific knowledge distilled from vulnerable-patched code pairs. Its knowledge base represents each vulnerability through functional semantics, vulnerability causes, and corresponding patches. At inference, an LLM generates an abstract purpose and detailed behavioral description of the code under analysis; *Vul-RAG* uses these together with the raw code as three retrieval queries. It applies sparse BM25 retrieval, which ranks entries by lexical term matching, and combines the resulting candidate lists using reciprocal rank fusion. The retrieved items are then examined sequentially by the LLM to determine whether the code exhibits a retrieved vulnerability cause without the corresponding patch behavior.

VulTriage [39] augments vulnerability detection through three complementary context paths targeting program structure, program semantics, and vulnerability knowledge. For knowledge retrieval, it generates up to two coarse natural-language vulnerability predictions of the code under analysis in a first step and uses these predictions as queries to a CWE-derived knowledge base. It performs hybrid retrieval by combining dense semantic similarity using *bge-m3* embeddings with sparse lexical matching. The retrieved CWE descriptions and code examples are then combined with the code under analysis, structural context, and semantic summary for the final prediction.

3.2 Datasets

In the evaluation, we distinguish between the original datasets used by each vulnerability detection system and a common dataset used for cross-system comparison. For RQ1, we retain each system’s original dataset and data split (including the system-specific knowledge base) to reproduce its reported performance. For the unified benchmark (RQ2), we use PrimeVul [7] as the common dataset. PrimeVul was introduced to address limitations of earlier vulnerability datasets, particularly noisy labels, duplicate samples, and data leakage across training and evaluation sets [7]. The full dataset (v0.1) contains 6,968 vulnerable and 228,800 benign functions spanning 94 CWEs and employs a chronological train, validation, and test split. For the benchmark, we specifically use the paired subset of PrimeVul, i.e., **PrimeVul Paired**: each vulnerable function is matched with its corresponding patch, resulting in 5480 pairs across 88 CWEs, making it particularly suitable for evaluating whether a model can correctly distinguish vulnerable code from its patched counterpart. We use the train split as the basis for the knowledge base and the test split for testing. For the component analysis in RQ3, specifically the knowledge retrieval, we additionally construct test set probes, i.e., randomly sample from the test sets (see Appendix A).

3.3 Metrics

Detection Performance. We assess detection performance using the standard classification metrics: Accuracy, Precision, Recall, and F1-score. While these metrics quantify performance at the level of individual functions, they do not capture whether a model can distinguish a vulnerable function from its patched non-vulnerable counterpart. Following the pairwise evaluation protocol introduced for PrimeVul [7], we report **Pairwise Accuracy** [8]. A vulnerability-patch pair is counted as correctly classified only if the vulnerable instance is predicted as vulnerable *and* its corresponding patched instance is predicted as non-vulnerable: $\text{Pair. Acc.} = \frac{1}{N} \sum_{i=1}^N \mathbf{1}(\hat{y}_i^{\text{vuln}} = 1 \wedge \hat{y}_i^{\text{patch}} = 0)$, where N denotes the number of pairs. Since paired instances differ primarily in the security-relevant changes introduced by the patch, this metric provides a stricter test of whether a model correctly distinguishes vulnerable from patched code.

Retrieval Effectiveness. For evaluating retrieval effectiveness, we adopt **Hit@k** and Mean Reciprocal Rank (**MRR**) [11], treating a retrieved item as a successful match if it shares the queried code’s

ground truth CWE, considering both exact matches and hierarchical CWE parent/child relaxations (cf. Tamberg and Bahsi [38]). $\text{Hit}@k$ measures the proportion of queries for which at least one successful match occurs within the top- k retrieved items: $\text{Hit}@k = \frac{1}{N} \sum_{i=1}^N \mathbf{1}(r_i \leq k)$, where N is the number of queries and r_i denotes the rank of the first successful match for query i . MRR captures how high the first successful match is ranked, averaged across all queries: $\text{MRR} = \frac{1}{N} \sum_{i=1}^N \frac{1}{r_i}$.

3.4 Model Selection

Several of the considered RAG4SVD systems originally rely on proprietary models, e.g., GPT-4 [25], or use open-weight models of scales typically requiring API services, e.g., DeepSeek-V3 [6] with 685B parameters. For the unified evaluation, we select a common pool of 22 open-weight models from 7 model families: Qwen [15, 28–31, 44], Llama [12], Phi [1, 23], Gemma [40], NextCoder [2], DeepSeek [5], and Mistral [16]. The pool spans parameter scales from approximately 3B to 32B, deliberately focusing on scales that remain amenable to practical local and on-premises deployment. The selection further includes both general-purpose and code-specialized models. Where available, we include multiple parameter scales from the same family, allowing us to additionally examine the effect of model scale. Unless otherwise stated, we use the full model pool consistently across experiments. The complete model lineup and checkpoints are reported in Appendix B.

3.5 Implementation Details

To enable a consistent evaluation across systems, we integrate all considered RAG systems into a unified local inference pipeline using Hugging Face² and the Transformers library. Systems that originally relied on API-based models were adapted by replacing their API calls with a common interface for locally hosted open-weight models. We preserve all other system logic, prompts, retrieval configurations, and system-specific hyperparameters.

Minor implementation changes were necessary to accommodate differences between proprietary and open-weight models. In particular, some open-weight models do not always adhere as reliably to requested output formats, e.g., requiring `<result>YES/NO<\result>` tags [8], which requires more robust parsing of generated responses. We therefore hardened system-specific output parsers where necessary to tolerate formatting variations without changing the semantic interpretation of model outputs. Detailed system-specific changes are documented in the replication package.

All retrieval and detection experiments with locally hosted open-weight models were executed on a high-performance computing cluster equipped with NVIDIA L40S 48 GB and NVIDIA H100 80 GB GPUs. The only exception to local inference is the LLM-as-a-Judge analysis in RQ3. Following the judge quality assessment by Li et al. [21], we use GPT-oss-120B [26] as the judge model and access it via the Blablador API³ due to its computational requirements. The judge is used only for evaluating generated abstractions and does not participate in retrieval or vulnerability detection.

4 Evaluation

In this section, we report the empirical evaluation of the considered RAG4SVD systems, structured around the derived research questions RQ1-RQ3. We first determine whether reported results can be reproduced (RQ1), then compare reproducible systems using a unified benchmark (RQ2), and finally isolate individual RAG components (RQ3).

²<https://huggingface.co>, accessed 11-09-2026.

³The Blablador API, provided by Jülich Supercomputing Centre, is accessible to researchers: https://sdlaml.pages.jsc.fz-juelich.de/ai/guides/blablador_api_access/, accessed 11-09-2026.

4.1 RQ1 Reproducibility

Reproducibility is a prerequisite for meaningful benchmarking. If systems cannot be faithfully reproduced, differences observed in subsequent comparisons may reflect implementation artifacts rather than underlying methods. For RQ1, we focus on systems that report results for at least one open-weight model. This criterion includes SVD-Bench, Llama-VD, LLM4Vuln, and Vul-RAG, while excluding GRACE and VulTriage, whose evaluations rely exclusively on proprietary models.

For the considered systems, we assess whether the reported results can be *reproduced in a local open-weight inference setting*. Where a study evaluates multiple datasets or models, we reproduce these settings separately. We repeat each experiment three times to account for inference variability; results are averaged across runs. Following Nong et al. [24], we quantify reproducibility using the absolute relative deviation between reproduced and reported results. Deviations below 1%, between 1% and 5%, and above 5% are classified as reproducible, weakly reproducible, and not reproducible, respectively. Fig. 3 summarizes the results across all considered systems.

SVD-Bench. We reproduce the results of SVD-Bench across its Python, Java, and JavaScript evaluation settings. Reproducibility does not hold consistently across this language coverage: deviations exceed 5% for Python and Java, while selected JavaScript metrics fall within the weakly reproducible range. The largest deviation occurs for recall on the Python dataset (58.2%), indicating that the reproduced implementation does not recover the reported performance.

Llama-VD. We reproduce the results of Llama-VD for Llama-3.1-8B on both originally evaluated datasets, Big-Vul and PrimeVul. Reproducibility is consistent across these datasets, with nearly all reported metrics deviating by less than 1%; only recall marginally exceeds this threshold (1.0-1.1%).

LLM4Vuln. LLM4Vuln reports results for different detection models, including three open-weight models, but still relies on GPT-4.1 for summary generation and output evaluation and, thus, cannot be reproduced with its original configuration in a fully open-weight reproduction setting. We therefore substitute these components with open-weight alternatives. We chose the substitutes (summary: Qwen3-4B, judge: Gemma-3-27B) through an ablation of candidate models based on their error rate and ability to produce correctly parseable outputs (cf. replication package). Despite using the closest-performing substitutes, the reproduced results deviate by more than 5% from the reported results, rendering LLM4Vuln not reproducible under a fully open-weight setting. Unlike the other considered systems, this deviation is not attributable to, e.g., parsing or inference variance alone, since LLM4Vuln depends on unavailable proprietary components. The reported results here

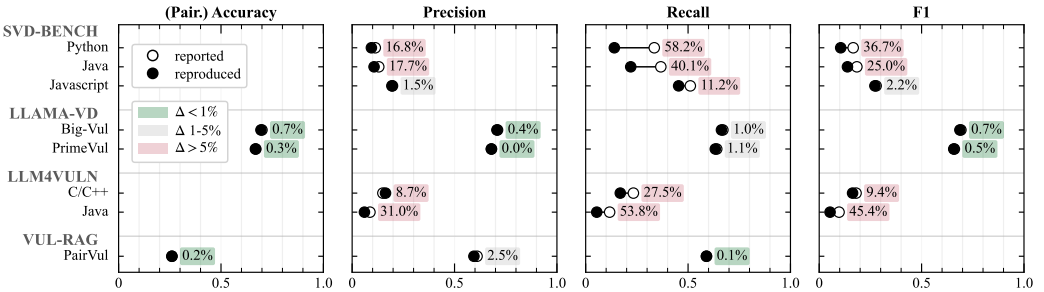


Fig. 3. Reproducibility of considered RAG4SVD systems. Absolute relative deviation between $\circ$ reported and $\bullet$ reproduced results for each metric reported, averaged across all evaluated open-weight models. Lower values indicate higher reproducibility; deviations below 1% are considered **reproducible**, 1-5% **weakly reproducible**, and above 5% **not reproducible**. See Appendix C for the absolute differences.

reflect a model substitution rather than a reproduction of the original configuration, making a deviation from the reported results expected.

Vul-RAG. We reproduce the results of Vul-RAG for Qwen2.5-Coder-32B on the PairVul dataset. The reproduced results closely match the reported performance, with deviations below 1% for accuracy and recall; precision exhibits a small deviation of 2.5%, i.e., is weakly reproducible.

Finding #1: Reproducibility varies substantially across the considered RAG4SVD systems, with potential contributing factors including parser hardening and inference non-determinism. For systems that require substituting proprietary models, reproducibility in an open-weight setting is unattainable.

4.2 RQ2 Unified Benchmark

We evaluate the considered systems under a common dataset, metric suite, and model pool to enable a controlled cross-system comparison. Notably, we are not estimating each system’s best possible performance; we assess how the systems transfer under a controlled open-weight environment. Accordingly, we exclude LLM4Vuln from the unified benchmark. LLM4Vuln’s modular pipeline relies on GPT-4.1 for summarization and judge-based evaluation such that evaluating it in an open-weight inference setting would require model substitutions, which introduces confounds beyond the choice of detection backbone. To further separate detection performance from parsing failures and prompt-specific instruction-following issues, we report a configuration only if at least 95% of pairs yield a correctly parsed prediction.

System Ranking. Table 2 summarizes the performance across systems and backbone models. Averaged over the intersection of models that yielded a prediction for *all* systems, Vul-RAG achieves

Table 2. Performance comparison across RAG4SVD systems on the PrimeVul Paired dataset. We report a cell only if at least 95% of pairs yielded a correctly parsed prediction. **Best** and **worst** pairwise accuracy per system highlighted. For the best configuration per system, we repeat inference 3× and report mean ± std. The system average is computed over the intersection of models (marked with *) that yielded a prediction for *all* systems, and over the top-5 performing models per system.

LLM	SVD-Bench		GRACE		Llama-VD		Vul-RAG		VulTriage	
	Pair. Acc.	F1	Pair. Acc.	F1	Pair. Acc.	F1	Pair. Acc.	F1	Pair. Acc.	F1
Qwen2.5-Coder-3B	0.07	0.33	0.04	0.62	0.07	0.45	-	-	-	-
Qwen2.5-Coder-14B*	0.09	0.48	0.02	0.39	0.07	0.46	0.22 ± 0.01	0.55	0.07	0.14
Qwen2.5-Coder-32B*	0.09	0.43	0.04	0.39	0.11	0.48	0.16	0.53	0.21 ± 0.00	0.37
Qwen2.5-3B	0.13	0.49	0.10	0.56	0.10	0.46	0.12	0.51	-	-
Qwen2.5-14B	0.12 ± 0.01	0.53	0.04	0.46	0.09	0.49	0.18	0.55	-	-
Qwen2.5-32B	0.12	0.56	0.03	0.44	0.13	0.48	0.16	0.56	-	-
Qwen3-4B	0.10	0.47	0.10	0.26	0.09	0.47	0.17	0.54	-	-
Qwen3.5-9B	-	-	0.05	0.17	0.15 ± 0.00	0.50	-	-	-	-
Qwen3.6-27B	-	-	0.01	0.01	0.06	0.42	0.14	0.56	-	-
QwQ-32B	0.12	0.58	0.17 ± 0.00	0.62	0.06	0.43	0.21	0.57	-	-
Llama-3.2-3B	0.09	0.37	0.01	0.67	0.12	0.48	-	-	-	-
Llama-3.1-8B	0.12	0.46	0.00	0.67	0.12	0.49	0.12	0.53	-	-
Phi-4-mini	0.11	0.51	0.09	0.55	0.09	0.46	-	-	-	-
Phi-4	0.10	0.36	0.04	0.42	0.11	0.49	0.14	0.56	-	-
Gemma-3-4B	0.10	0.47	0.07	0.64	0.15	0.51	0.19	0.50	-	-
Gemma-3-12B*	0.08	0.36	0.04	0.49	0.09	0.48	0.20	0.54	0.06	0.63
Gemma-3-27B*	0.07	0.38	0.03	0.58	0.08	0.48	0.20	0.55	0.21	0.70
NextCoder-14B*	0.08	0.43	0.02	0.40	0.07	0.46	0.22	0.56	0.07	0.13
NextCoder-32B	0.12	0.51	0.06	0.40	0.07	0.48	0.19	0.55	-	-
DeepSeek-R1-8B	0.12	0.48	0.14	0.58	0.09	0.46	0.21	0.51	-	-
DeepSeek-R1-32B	0.10	0.50	0.16	0.51	0.10	0.49	0.19	0.53	-	-
Mistral-v0.3-7B	0.09	0.41	0.06	0.57	0.14	0.49	-	-	-	-
Average (n = 5, *intersection)	0.08	0.41	0.03	0.45	0.08	0.47	0.20	0.55	0.12	0.40
Average (n = 5, best)	0.12	0.53	0.13	0.51	0.14	0.49	0.21	0.55	0.12	0.40

the highest mean pairwise accuracy (0.20), followed by VulTriage (0.12), SVD-Bench and Llama-VD (0.08), and GRACE (0.03). Notably, SVD-Bench and Llama-VD, which both implement example-retrieval RAG using dense retrieval (with different embedding models), converge to the same mean pairwise accuracy. Considering the top-5 best performing models per system, the ordering slightly shifts: Vul-RAG reaches 0.21 pairwise accuracy, followed by Llama-VD (0.14), GRACE (0.13), SVD-Bench (0.12), and finally VulTriage (0.12). Considering the *strongest individual configurations*, we repeat each configuration three times to assess inference variability and report the mean pairwise accuracy $\pm$ standard deviation. Vul-RAG reaches 0.22 ± 0.01 , compared with 0.21 ± 0.00 for VulTriage, 0.17 ± 0.00 for GRACE, 0.15 ± 0.00 for Llama-VD, and 0.12 ± 0.01 for SVD-Bench. The low standard deviations indicate limited run-to-run inference variability; we therefore report single-run results for the remaining benchmark configurations.

Pairwise accuracy also reveals failure modes that are obscured by F1 score alone. For example, Llama-3.2-3B and Llama-3.1-8B under GRACE achieve F1 scores of 0.67, while their pairwise accuracy is only 0.01 and 0.00, respectively. For the pairwise evaluation setting, this combination is attributable to almost always predicting vulnerable. Despite a seemingly strong F1 score, the system fails to distinguish vulnerable functions from their patched counterparts.

Backbone Sensitivity. Performance varies markedly with the underlying detection model, but we observe no consistent advantage through model scale or code specialization where model families match. Within the Qwen2.5 family, for example, performance does not increase monotonically with parameter scale across systems, and the corresponding coder variants do not systematically outperform their general-purpose counterparts. Instead, the strongest backbone is pipeline-specific.

Parsing Robustness. The benchmark additionally exposes substantial differences in output-format robustness across systems. GRACE and Llama-VD yield sufficiently parseable predictions across the evaluated model pool. In contrast, VulTriage, which reports SOTA pairwise accuracy of 0.34 using GPT-4o on PrimeVul Paired [39], meets the 95% parsing threshold for only 5 tested open-weight models, indicating limited transferability of its prompting and output-format beyond the original proprietary-model setting. Instruction following and detection performance should therefore be treated as distinct system properties: a pipeline may perform well for a compatible backbone while remaining difficult to evaluate reliably with others due to prompt or output-format sensitivity.

Finding #2: Using a common benchmark, RAG4SVD systems differ substantially in detection performance, backbone sensitivity, and parsing robustness. Vul-RAG achieves the highest mean pairwise accuracy, while reported SOTA rankings under the systems’ original evaluation settings do not transfer to a common open-weight setting. These results show that system-level gains strongly depend on the backbone model and evaluation setting used.

4.3 RQ3 Component Analysis

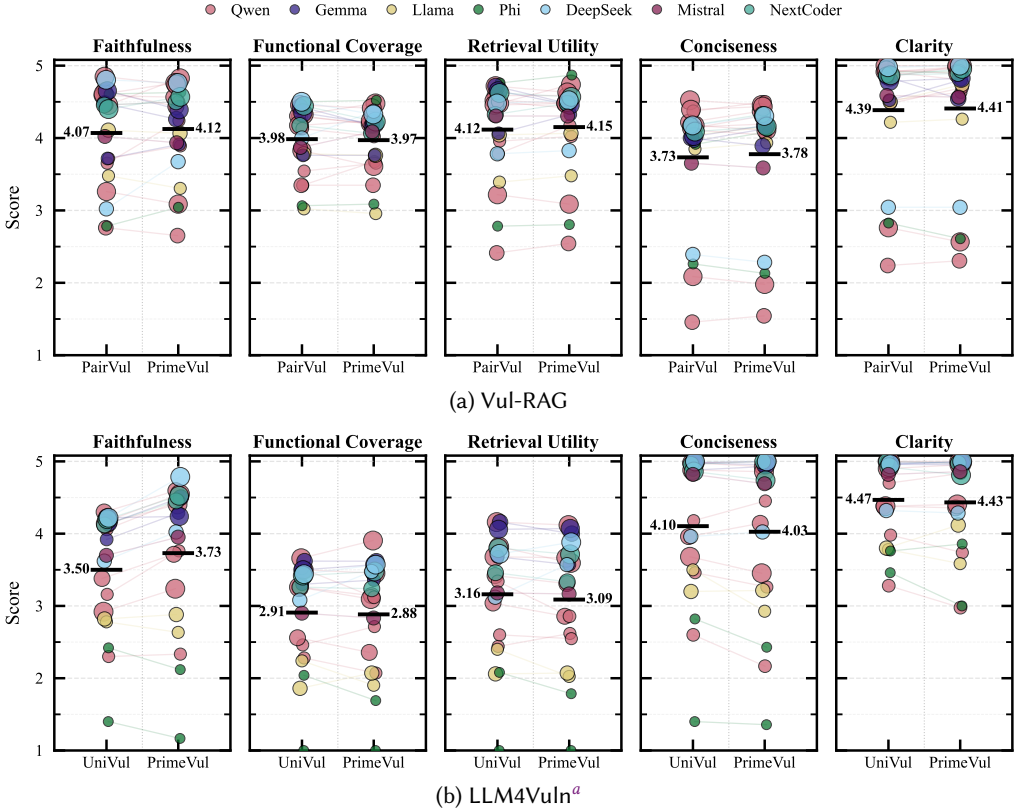
RAG4SVD pipelines combine multiple components, e.g., input abstraction, knowledge retrieval, and retrieval-augmented detection, as shown in Fig. 1. However, prior work typically reports only end-to-end detection performance, leaving open which components drive the observed improvements. We complement the *extrinsic* evaluation in RQ2 with an *intrinsic* analysis that isolates and evaluates individual pipeline components. For this analysis, we focus on Vul-RAG [8] and LLM4Vuln [37], as both systems expose separable abstraction, retrieval, and detection stages and use retrieved knowledge as primary external augmentation, which facilitates component-level attribution.

4.3.1 Input Abstraction. We first evaluate the quality of input abstractions, i.e., whether using summaries of code functionality preserves information necessary for retrieval. Following prior work on LLM-based code summarization evaluation [4, 34, 36, 42, 43], we use an LLM-as-a-Judge

and assess each summary along five dimensions. Four of these dimensions capture established summary-quality properties: *Faithfulness* (support by the input code), *Functional Coverage* (coverage of the code’s primary behavior), *Conciseness* (informativeness without unnecessary detail), and *Clarity* (readability and unambiguity). For the RAG setting, we additionally introduce *Retrieval Utility*, which assesses whether the summary preserves discriminative semantic information for retrieving relevant knowledge. Each dimension is scored from 1 to 5. Consistent with the focus on open-weight evaluation and following Li et al. [21], we use GPT-oss-120B as the judge.

For the evaluation, we retain each system’s abstraction prompt and evaluate summaries generated by the different models in the pool for test codes sampled from the original and PrimeVul test sets (cf. Appendix A). Vul-RAG asks the model to extract the purpose and functionality of the code in a specific format, whereas LLM4Vuln requests a short summary (less than three sentences) intended to support search over the vulnerability-knowledge database.

Figure 4 visualizes judge-assessed summary quality across the model pool. Vul-RAG summaries score consistently high in Faithfulness, Functional Coverage, and Retrieval Utility, but lower in Conciseness. By contrast, LLM4Vuln summaries are generally more concise and clear, but provide



^aDue to dependency conflicts in the LLM4Vuln environment, we excluded Qwen3.5-9B and Qwen3.6-27B from its model pool. As a robustness check, we recomputed all means with and without these models and observed no material differences.

Fig. 4. Summary-quality evaluation for system-specific and PrimeVul test probes, with mean scores averaged over the model pool. Marker color encodes model family and marker size $\propto$ increasing parameter count.

less Functional Coverage and Retrieval Utility. This difference reflects the prompt objectives: Vul-RAG emphasizes purpose and functionality, whereas LLM4Vuln explicitly favors short summaries. Within each system, mean scores remain largely stable across dimensions and test sets. These results suggest that judged abstraction quality is driven more strongly by the system-specific summarization prompt than by the code to be summarized.

Furthermore, several models, including QwQ-32B, Gemma-3-12B, and Qwen2.5-Coder-32B, perform strongly under both systems, indicating that some models perform consistently well across abstraction tasks. At the same time, several models exhibit pronounced failure cases. For example, DeepSeek-R1-8B under Vul-RAG produces verbose reasoning traces that primarily reduce Conciseness and Clarity. Under LLM4Vuln, Phi-4 represents a more severe failure case, scoring poorly in Faithfulness, Functional Coverage, and Retrieval Utility; manual inspection shows that it returns "Code snippet" for every evaluated query.

Finding #3: Abstraction quality depends on the system-specific abstraction prompt, with no clear trend attributable to model capabilities; robustness must be verified per pipeline.

Judge Sensitivity. To assess whether the results depend on the selected LLM judge, we repeat the evaluation with Qwen2.5-32B and QwQ-32B. Table 3 reports ordinal Krippendorff’s α and mean pairwise absolute deviation (MAD) across the judges. Higher α indicates stronger agreement beyond chance, with $\alpha = 1$ representing perfect agreement. MAD computes the average absolute score difference between judge pairs on the 1-5 scale. Vul-RAG’s α ranges from 0.16 to 0.38, which indicates high judge sensitivity. LLM4Vuln has higher agreement in Functional Coverage ($\alpha = 0.63$) and Retrieval Utility ($\alpha = 0.59$), but the other dimensions remain judge-sensitive. Despite differences in absolute scores, the judges preserve the LLM4Vuln abstraction profile, consistently rating Clarity and Conciseness highest, see Tab. 3 (b). For Vul-RAG, judge choice has a stronger effect on individual scores, particularly Retrieval Utility, but the overall ranking of dimensions remains broadly similar.

4.3.2 Knowledge Retrieval. As a high-quality code summary can read well without necessarily helping vulnerability knowledge retrieval, we examine retrieval in practice. Therefore, we evaluate each knowledge base from two complementary perspectives: *Knowledge Coverage* and *Retrieval Effectiveness*. Knowledge coverage assesses whether the knowledge base contains knowledge relevant to the vulnerable codes represented in the test set, e.g., CWE type alignment. Retrieval effectiveness measures whether the retriever can successfully identify this relevant knowledge, quantified using Hit@ k and MRR. Separating these two dimensions allows us to identify retrieval failures caused by missing knowledge alignment and those caused by ineffective retrieval.

Table 3. Inter-judge agreement and score sensitivity for the abstraction-quality evaluation. (a) Ordinal Krippendorff’s α and mean pairwise absolute deviation (MAD) across the judges. (b) Mean scores by judge.

(a) Inter-judge agreement.					(b) Mean judge scores.							
Dimension	Vul-RAG		LLM4Vuln		Dimension	GPT-oss-120B		Qwen2.5-32B		QwQ-32B		
	α	MAD	α	MAD		System	PrimeVul	System	PrimeVul	System	PrimeVul	
Faithfulness	0.19	0.81	0.42	0.99	Vul-RAG	Faithfulness	4.07	4.12	3.92	3.90	4.58	4.58
Functional Coverage	0.24	0.69	0.63	0.73		Functional Coverage	3.98	3.97	3.98	3.95	4.63	4.63
Retrieval Utility	0.19	0.84	0.59	0.77		Retrieval Utility	4.12	4.15	3.40	3.43	4.39	4.28
Conciseness	0.16	0.79	0.28	0.82		Conciseness	3.73	3.78	3.81	3.85	4.58	4.56
Clarity	0.38	0.48	0.36	0.59		Clarity	4.39	4.41	4.40	4.44	4.82	4.79
System-specific dataset (PairVul for Vul-RAG, UniVul for LLM4Vuln) and PrimeVul probes.					LLM4Vuln	Faithfulness	3.50	3.73	2.92	2.90	3.71	3.77
						Functional Coverage	2.91	2.88	2.70	2.61	3.45	3.35
						Retrieval Utility	3.16	3.09	2.40	2.34	3.17	3.07
						Conciseness	4.10	4.03	4.28	4.37	4.06	3.99
						Clarity	4.47	4.43	4.28	4.45	4.46	4.45

Knowledge Coverage. Vul-RAG constructs the knowledge base from historical CVEs, extracting functional semantics, vulnerability causes, and fixing solutions using GPT-3.5 [8]. The system targets 10 CWEs from the Linux kernel and maintains a dedicated knowledge base and test set for each CWE. By construction, the knowledge base and test data are aligned. Vul-RAG also allows for simple regeneration of the knowledge base. LLM4Vuln uses a *generic* knowledge base generated from CWE descriptions [37]: GPT-4.1 generates 10 code examples for each of 92⁴ CWEs, and further summarizes functionality and root cause. While this design aims to provide generic vulnerability coverage, the knowledge base is weakly aligned with the curated test data. Specifically, only 6 of the 92 CWEs present in the knowledge base overlap with the 23 CWEs covered in the UniVul test set, which align with only 60 of 920 entries (less than 7%).

Retrieval Effectiveness. For each system, we execute the original retrieval pipeline on summaries generated for the sampled test functions. We record the ranked knowledge items returned for each query and count a retrieval as relevant when the retrieved item matches the ground-truth CWE of the query function. To account for the hierarchical structure of CWE, we also consider a relaxed match in which parent or child CWE categories are treated as relevant. Hit@*k* therefore measures

⁴The original LLM4Vuln paper reports 86 CWE categories. Using the publicly available code and configuration, we identified 92 distinct CWE categories.

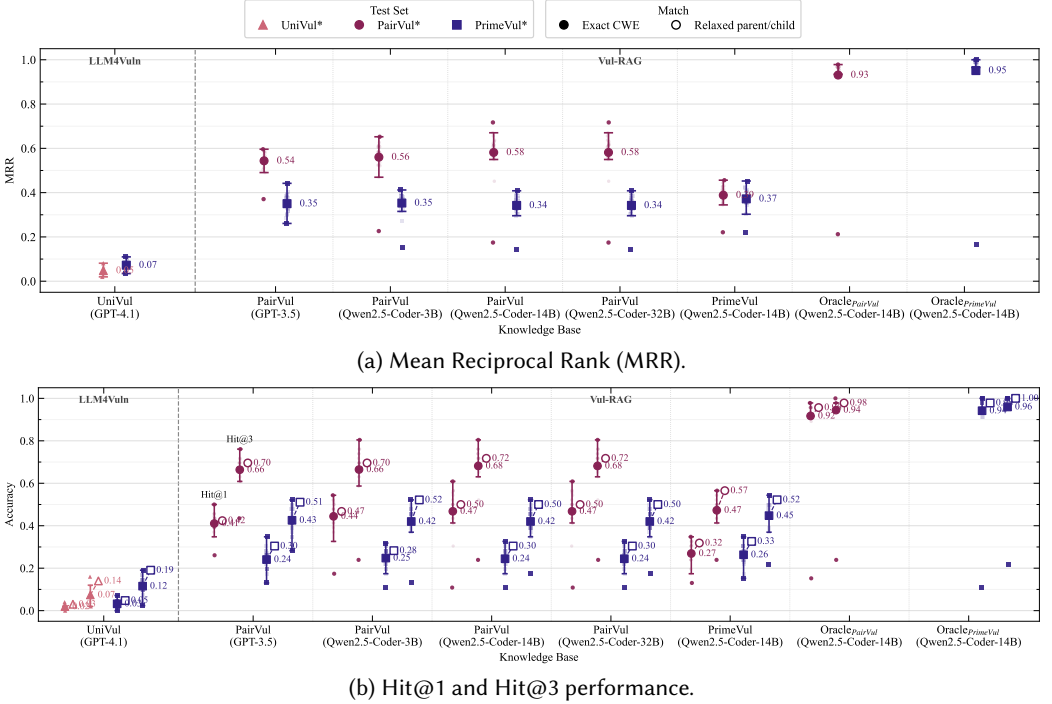


Fig. 5. Retrieval effectiveness across knowledge base and test probe combinations for LLM4Vuln and Vul-RAG. Knowledge bases are generated from the training sets using the model indicated in parentheses, while marker shape and color identify the test set probe. Large filled markers show the mean across input-abstraction models; highlighted points indicate the minimum and maximum observed values; whiskers cover 1.5×IQR. For Hit@*k*, the line connects the mean under exact (●) with the mean under relaxed CWE matching (○).

whether at least one relevant item appears among the top- k results, while MRR captures the rank of the first such match. Figure 5 visualizes the results.

For Vul-RAG, retrieval performs moderately well for the PairVul test probe on the original PairVul knowledge base (mean MRR 0.54, Hit@3 0.66), consistent with the alignment analysis above, but substantially worse for the PrimeVul test probe (mean MRR 0.35, Hit@3 0.43). For LLM4Vuln, retrieval is uniformly weak across both UniVul and PrimeVul test probes (MRR 0.07, Hit@3 0.12 for PrimeVul), in line with its limited alignment between the knowledge base and the test sets.

To establish an upper bound on retrieval, we construct an oracle setting in which the knowledge base is generated from the test set, guaranteeing that a ground-truth item is present in the retrieval pool. For Vul-RAG, oracle MRR is near-ceiling when the knowledge base and test set are aligned (0.93 for PairVul, 0.95 for PrimeVul), i.e., the retrieval mechanism can recover relevant knowledge effectively when sufficient task-aligned knowledge is available.

Finding #4: Across the analyzed pipelines, knowledge base coverage and alignment with the target distribution are crucial for effective retrieval. Under oracle knowledge, when relevant knowledge is guaranteed to be present, Vul-RAG retrieval reaches near-ceiling effectiveness.

For Vul-RAG, we further compare knowledge bases regenerated with three models of increasing scale (Qwen2.5-Coder-3B/14B/32B) against the original GPT-3.5-generated PairVul knowledge base. On the sampled PairVul test set, mean retrieval improves only slightly with increasing generation model scale (MRR: 0.56 $\rightarrow$ 0.58; Hit@3: 0.66 $\rightarrow$ 0.68). This trend does not hold on the sampled PrimeVul test set, where retrieval remains flat. Thus, within the tested models and a fixed knowledge base construction setting, scaling the generation model yields no generalizable additional benefit.

In contrast, retrieval varies substantially more with the model used for input abstraction. For example, for the original PairVul knowledge base, MRR on the PairVul probe ranges from 0.37 to 0.60 across models. Although the generator can itself affect the quality and alignment of the resulting knowledge base, these results indicate that, among the tested generators, retrieval is more sensitive to how the query is formulated than to which model generated the knowledge base.

Finding #5: Within a fixed knowledge base construction setting, retrieval effectiveness is more sensitive to the query abstraction model than to the knowledge base generation model.

4.3.3 Vulnerability Detection. We isolate the detection stage to determine whether the LLM can exploit relevant vulnerability knowledge and translate it into a correct vulnerability prediction. We conduct two complementary experiments. First, we fix Qwen2.5-Coder-14B, which performed best for Vul-RAG in RQ2, as the detection model and vary the Vul-RAG knowledge base to isolate how much of detection performance is determined by the available knowledge. Second, we fix an oracle knowledge base and vary the detection model to assess how model capabilities bound performance.

Sensitivity to the Supplied Knowledge. Figure 6a visualizes the results. Sub-sampling the original Vul-RAG knowledge base to 25%/50%/75% of its size yields a consistent upward trend (PairVul: 0.20 $\rightarrow$ 0.24 $\rightarrow$ 0.26; PrimeVul: 0.17 $\rightarrow$ 0.19 $\rightarrow$ 0.23), but accuracy then drops at 100% size; i.e., the 75% subset outperforms the full knowledge base. More knowledge is not uniformly beneficial; we hypothesize this trend reflects either noise from near-duplicate or low-relevance entries diluting top- k retrieval precision, or a higher share of lower-quality entries being surfaced at full scale.

Regenerating the knowledge base with Qwen2.5-Coder-14B improves pairwise accuracy from 0.23 to 0.36, a 52.57% increase. This gain, however, is not monotonic in generator scale (14B: 0.36 > 32B: 0.32 > 3B: 0.28 on PairVul). One possible explanation is an implicit alignment between the knowledge generator and the downstream detector: knowledge generated by the same model may better match the preferred representations or abstraction.

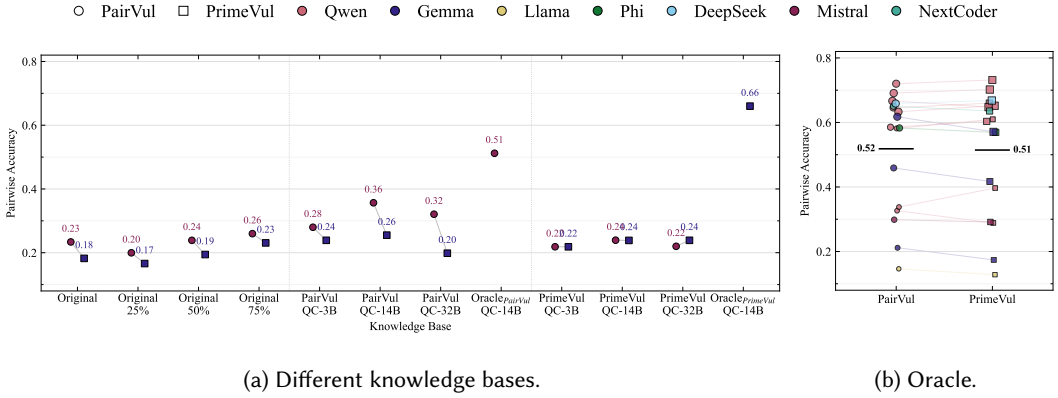


Fig. 6. Vul-RAG detection stage. (a) Pairwise Accuracy across knowledge bases with Qwen2.5-Coder-14B fixed as the detector. QC = Qwen2.5-Coder. (b) Pairwise Accuracy when oracle knowledge is supplied (for those models that parsed at least 95% of pairs for both test sets, which excludes 5 models).

Knowledge bases generated from the PrimeVul training set achieve 0.22–0.24 pairwise accuracy regardless of which test set they are evaluated against. This observation contrasts with the PairVul-derived knowledge bases, which show a clear domain-alignment effect (e.g., pairwise accuracy of 0.36 on its native test set vs. 0.26 cross-dataset). Together with the higher generation error rate observed for the PrimeVul-based knowledge bases (cf. Appendix A), the results suggest that the current generation procedure produces less useful knowledge for PrimeVul, possibly due to the longer functions or different vulnerability distribution [17].

Finding #6: In the Vul-RAG pipeline, detection performance is sensitive to the knowledge base, but does not improve monotonically with knowledge base size or generator scale. The best performance is obtained with Qwen2.5-Coder-14B used for both knowledge generation and vulnerability detection, which points to a generator-detector alignment as an opportunity for improving detection.

Detection under Oracle Knowledge. To approximate best-case upstream conditions, we use the test set-specific oracle knowledge bases. Detection is performed on the same test set, with retrieval restricted to knowledge derived from that test set. This oracle setting intentionally uses test-derived knowledge and is therefore diagnostic rather than deployable; it estimates detector performance when upstream knowledge availability and retrieval are made near-optimal.

Figure 6b visualizes the results. Mean pairwise accuracy reaches 0.51 on PrimeVul (0.66 for Qwen2.5-Coder-14B), substantially above Vul-RAG under the unified benchmark in RQ2, where Qwen2.5-Coder-14B reaches the best result of 0.22 pairwise accuracy. The strongest oracle detectors are larger Qwen-family models, with Qwen3.6-27B reaching 0.73 on PrimeVul and 0.72 on PairVul, whereas Llama3.2-3B remains at only 0.13 pairwise accuracy on PrimeVul and 0.15 on PairVul despite operating under the same favorable retrieval conditions. The large spread under oracle knowledge shows that detector capability remains an independent bottleneck.

Finding #7: Oracle retrieval does *not* solve vulnerability detection. Even under near-optimal oracle conditions, mean pairwise accuracy remains only 0.51, with the strongest detector reaching 0.73. Thus, correctly applying retrieved knowledge remains a substantial bottleneck.

Across all three analyzed components, the results suggest that improving RAG4SVD requires optimizing the alignment between pipeline stages, rather than simply scaling models or knowledge bases. Abstraction quality is driven primarily by the system-specific summarization objective (Finding #3); retrieval effectiveness depends on query formulation and knowledge base alignment with the target distribution (Findings #4 and #5); and detection performance is influenced more by the alignment of the supplied knowledge than by knowledge base size or generator scale (Finding #6). Even where scaling does help, particularly at the detection stage, it closes only part of the gap: mean pairwise accuracy remains near 0.50 even under oracle knowledge (Finding #7).

5 Threats to Validity

Internal Validity. We re-implemented and adapted existing RAG4SVD systems into a unified benchmark framework. Although we preserve system logic, prompts, and hyperparameters where possible, implementation differences, parser hardening, and model substitutions may affect reproduced results. We mitigate these risks by documenting all adaptations in the replication package and repeating experiments where applicable. All RAG4SVD inference pipelines use locally hosted open-weight models; the only remote dependency is the open-weight GPT-oss-120B judge used for the abstraction-quality analysis in RQ3.

Construct Validity. Pairwise accuracy provides a stricter measure of vulnerable-patched discrimination than instance-level metrics, while excluding configurations with fewer than 95% parseable predictions may favor systems with more robust output formats. We therefore report parsing success in the replication package. For retrieval, we define relevance by ground-truth CWE agreement, including parent/child relations. As CWE agreement does not necessarily imply semantic or vulnerability-specific relevance, we interpret these metrics as measuring knowledge alignment rather than actionable knowledge quality. The component analysis further relies on sampled test-set probes due to the computational cost of evaluating all model-knowledge base combinations, such that small differences may reflect sampling noise.

External Validity. The findings and conclusions of this work are limited to the systems, datasets, and models considered. We study six artifact-complete RAG4SVD systems, use PrimeVul Paired as the common benchmark, and evaluate a documented pool of 3B-32B open-weight models suitable for on-premises deployment. Results may differ for proprietary models, other programming languages, or vulnerability data distributions. Moreover, the component-level analysis focuses on two representative multi-stage pipelines and should therefore be interpreted as evidence for the examined systems rather than as a universal characterization of all RAG4SVD systems.

6 Conclusion

In this work, we examined RAG-based software vulnerability detection from the perspectives of reproducibility, cross-system comparability, and component-level attribution. Across six open-source RAG4SVD systems, we find that reported results do not consistently transfer to open-weight evaluation settings, and that system rankings can change substantially under a unified benchmark. In the presented component analysis of representative RAG4SVD pipelines, we further dissected input abstraction, knowledge retrieval, and detection to identify where future RAG4SVD systems should focus their engineering effort. As abstraction quality, e.g., code summarization, is shaped by the system-specific prompting objective, input abstractions should be optimized for retrieval utility rather than conciseness. As retrieval effectiveness depends on knowledge base coverage and alignment with the target distribution, these properties should be established beforehand, since poor retrieval can limit detection performance. Finally, oracle retrieval does *not* solve vulnerability detection: oracle knowledge containing ground truth information achieves MRR of 0.93–0.95, yet mean pairwise accuracy remains only 0.51.

Overall, these findings suggest that progress in RAG4SVD is unlikely to come from scaling individual components, such as models or knowledge bases, alone. Performance is governed by the alignment across component interfaces, e.g., abstraction to retrieval, knowledge base to target distribution, and retrieved knowledge to detector. Hence, future evaluations should complement end-to-end detection metrics with component-level evaluations of abstraction quality, knowledge base coverage, retrieval effectiveness, parsing robustness, and downstream knowledge use.

Acknowledgments

This work has been funded by the Federal Ministry of Research, Technology and Space (BMFTR) and the state of Baden-Württemberg (Program: Forschung an HAW, Grant No. 13HAW26PX4), and in part by the German Research Foundation (DFG) under project-ID 528745080 - FIP 68. The authors alone are responsible for the content of this paper. We thank the DACHS data analysis cluster, hosted at Hochschule Esslingen and co-funded by the MWK within the DFG’s "Großgeräte der Länder" program, for providing the computational resources necessary for this research. We also thank Fabian Schmidt for the insightful discussions throughout the experimental process.

A Dataset Statistics and Sampling

For the component-level analysis in RQ3, we construct sampled test sets that match the CWE distributions of the system-specific reference datasets. For Vul-RAG, we sample PrimeVul according to the ten CWEs represented in PairVul, selecting five instances per CWE where available. As PrimeVul contains only one CWE-264 instance, the resulting sample $\text{PrimeVul}^*_{\text{PairVul}}$ contains 46 vulnerable functions. For LLM4Vuln, we use the full UniVul test set as the reference distribution and sample PrimeVul to match its per-CWE counts where possible. This yields $\text{PrimeVul}^*_{\text{UniVul}}$ with 42 vulnerable functions across 18 overlapping CWEs. Tab. 4 summarizes the dataset and probe statistics as well as the knowledge base generation statistics.

B Model Lineup

Table 5 lists the 22 open-weight models with their checkpoints used in the evaluation. The model pool spans multiple model families, parameter scales, and specializations.

C Full Reproduction Results

Tab. 6 reports the absolute values underlying the RQ1 reproducibility analysis in Sect. 4.1. For further details, e.g., the calculation of deviations, we refer to the replication package.

Table 4. Dataset statistics. (a) Train and test datasets, reported with their number of vulnerable functions and CWEs. (b) Test set probes. (c) Vul-RAG knowledge base generation statistics (PairVul-specific CWE subset).

(a) Dataset statistics.					(c) Knowledge base generation.				
Dataset	Train		Test		Source	Generator	Expected	Generated	Errors
	#Vuln.	#CWEs	#Vuln.	#CWEs					
PrimeVul	3789	111	435	62	<i>Training-derived knowledge bases</i>				
PairVul	2317	10	586	10	PairVul	GPT-3.5 (original)	2317	–	–
UniVul	920	92	50	23	PairVul	Qwen2.5-Coder-3B	2317	2312	5
					PairVul	Qwen2.5-Coder-14B	2317	2316	1
					PairVul	Qwen2.5-Coder-32B	2317	2317	0
					PrimeVul	Qwen2.5-Coder-3B	2398	2347	51
					PrimeVul	Qwen2.5-Coder-14B	2398	2370	28
					PrimeVul	Qwen2.5-Coder-32B	2398	2374	24
(b) Test set probes.					<i>Oracle knowledge bases (test-derived)</i>				
System	Probe	#Vuln.		#CWEs	PairVul	Qwen2.5-Coder-14B	586	585	1
Vul-RAG	<i>PairVul</i> [*]	46		10	PrimeVul	Qwen2.5-Coder-14B	247	244	3
Vul-RAG	<i>PrimeVul</i> [*] _{PairVul}	46		10					
LLM4Vuln	UniVul	50		23					
LLM4Vuln	<i>PrimeVul</i> [*] _{UniVul}	42		18					

Table 5. Pool of pen-weight models used throughout the benchmark and component analysis.

Family	Model (Paper Abbreviation)	Scale	Specialization	Full Hugging Face Checkpoint	Context Size
Qwen	• Qwen2.5-3B [31]	3.1B	General	Qwen/Qwen2.5-3B-Instruct	32K
	• Qwen2.5-14B [31]	14.7B	General	Qwen/Qwen2.5-14B-Instruct	32K
	• Qwen2.5-32B [31]	32.5B	General	Qwen/Qwen2.5-32B-Instruct	32K
	• Qwen2.5-Coder-3B [15]	3.1B	Code	Qwen/Qwen2.5-Coder-3B-Instruct	32K
	• Qwen2.5-Coder-14.7B [15]	14B	Code	Qwen/Qwen2.5-Coder-14B-Instruct	32K
	• Qwen2.5-Coder-32.5B [15]	32B	Code	Qwen/Qwen2.5-Coder-32B-Instruct	32K
	• Qwen3-4B [44]	4.0B	General	Qwen/Qwen3-4B	32K
	• Qwen3.5-9B [29]	9.0B	General	Qwen/Qwen3.5-9B	256K
	• Qwen3.6-27B [30]	27.0B	General	Qwen/Qwen3.6-27B	256K
	• QwQ-32B [28]	32.5B	General	Qwen/QwQ-32B	128K
Llama	• Llama-3.2-3B [12]	3.2B	General	meta-llama/Llama-3.2-3B-Instruct	128K
	• Llama-3.1-8B [12]	8.0B	General	meta-llama/Llama-3.1-8B-Instruct	128K
Phi	• Phi-4-Mini [23]	3.8B	General	microsoft/Phi-4-mini-instruct	128K
	• Phi-4 [1]	14.7B	General	microsoft/phi-4	16K
Gemma	• Gemma-3-4B [40]	4.0B	General	google/gemma-3-4b-it	128K
	• Gemma-3-12B [40]	12.0B	General	google/gemma-3-12b-it	128K
	• Gemma-3-27B [40]	27.0B	General	google/gemma-3-27b-it	128K
NextCoder	• NextCoder-14B [2]	14.7B	Code	microsoft/NextCoder-14B	32K
	• NextCoder-32B [2]	32.5B	Code	microsoft/NextCoder-32B	32K
DeepSeek	• DeepSeek-R1-8B [5]	8.0B	General	deepseek-ai/DeepSeek-R1-Distill-Llama-8B	128K
	• DeepSeek-R1-32B [5]	32.5B	General	deepseek-ai/DeepSeek-R1-Distill-Qwen-32B	128K
Mistral	• Mistral-7B [16]	7.3B	General	mistralai/Mistral-7B-Instruct-v0.3	32K

Table 6. Absolute reproduction results for the systems evaluated in RQ1. $\circ$ denotes the reported result, $\bullet_i$ the i th reproduction run, and $\bar{\bullet}$ the mean across runs. SVD-Bench provides a seed and yields identical results across all three runs. For Llama-VD, precision, recall, and F1 refer to the vulnerable class.

SVD-Bench [45]										LLM4Vuln [37]									
Model	Python			Java			JavaScript			Model	C/C++			Java					
	Prec.	Rec.	F1	Prec.	Rec.	F1	Prec.	Rec.	F1		Prec.	Rec.	F1	Prec.	Rec.	F1			
CodeQwen1.5-7B	○ 0.11	0.52	0.18	0.11	0.48	0.18	0.19	0.56	0.29	QwQ-32B	● ₁ 0.21	0.19	0.14	0.08	0.02	0.11			
	● 0.08	0.20	0.11	0.08	0.25	0.12	0.20	0.50	0.28		● ₂ 0.18	0.16	0.13	0.03	0.01	0.04			
											● ₃ 0.19	0.17	0.13	0.04	0.01	0.06			
DeepSeek-Coder-7B	○ 0.11	0.32	0.16	0.14	0.31	0.19	0.19	0.38	0.25	○	0.26	0.33	0.29	0.14	0.12	0.13			
	● 0.08	0.15	0.11	0.10	0.17	0.13	0.19	0.34	0.25	○	0.19	0.17	0.13	0.05	0.01	0.07			
CodeGemma-7B	○ 0.11	0.26	0.15	0.13	0.41	0.19	0.18	0.54	0.27	Llama-3.1-8B	● ₁ 0.12	0.12	0.11	0.04	0.03	0.03			
	● 0.08	0.14	0.10	0.11	0.28	0.15	0.18	0.48	0.26		● ₂ 0.19	0.19	0.17	0.07	0.06	0.05			
											● ₃ 0.15	0.15	0.14	0.05	0.04	0.04			
StarCoder2-7B	○ 0.12	0.29	0.17	0.16	0.19	0.18	0.21	0.40	0.28		○	0.09	0.17	0.12	0.05	0.09	0.06		
	● 0.14	0.07	0.09	0.16	0.16	0.16	0.22	0.37	0.27		○	0.15	0.15	0.14	0.05	0.04	0.04		
CodeLlama-7B	○ 0.12	0.29	0.17	0.12	0.45	0.18	0.19	0.66	0.30	Phi-3-Mini-128K	● ₁ 0.21	0.17	0.21	0.08	0.08	0.08			
	● 0.09	0.14	0.11	0.09	0.24	0.13	0.20	0.58	0.29		● ₂ 0.17	0.15	0.18	0.08	0.08	0.08			
											● ₃ 0.19	0.16	0.19	0.08	0.08	0.08			
	○ 0.10	0.20	0.13	0.07	0.14	0.10				○	0.10	0.20	0.13	0.07	0.14	0.10			
	● 0.19	0.16	0.19	0.08	0.08	0.08				●	0.19	0.16	0.19	0.08	0.08	0.08			
Llama-VD [27] - Llama-3.1-8B										Vul-RAG [8] - Qwen2.5-Coder-32B									
Big-Vul				PrimeVul				PairVul				PairVul							
	Acc.	Prec.	Rec.	F1	Acc.	Prec.	Rec.	F1		Pair.	Acc.	Rec.	Prec.						
● ₁	0.69	0.70	0.65	0.68	0.66	0.68	0.63	0.65	● ₁	0.25	0.58	0.58							
● ₂	0.70	0.71	0.67	0.69	0.67	0.68	0.64	0.66	● ₂	0.25	0.59	0.60							
● ₃	0.70	0.71	0.67	0.69	0.67	0.68	0.63	0.66	● ₃	0.27	0.60	0.60							
○	0.70	0.71	0.67	0.69	0.67	0.68	0.64	0.66	○	0.26	0.59	0.61							
○	0.70	0.71	0.66	0.69	0.67	0.68	0.63	0.66	○	0.26	0.59	0.59							

References

- [1] Marah Abdin, Jyoti Aneja, Harkirat Behl, Sébastien Bubeck, Ronen Eldan, Suriya Gunasekar, Michael Harrison, Russell J. Hewett, Mojan Javaheripi, Piero Kauffmann, et al. 2024. *Phi-4 Technical Report*. arXiv:2412.08905
- [2] Tushar Aggarwal, Swayam Singh, Abhijeet Awasthi, Aditya Kanade, and Nagarajan Natarajan. 2025. *Robust Learning of Diverse Code Edits*. arXiv:2503.03656

- [3] Zhijie Chen, Luyao Xu, Zhihao Lin, Xiaolin Ju, and Xiang Chen. 2026. *A Systematic Literature Review of Retrieval-Augmented Generation Methods for the Software Vulnerability Lifecycle*. [ssrn:7113581](#)
- [4] Giuseppe Crupi, Rosalia Tufano, Alejandro Velasco, Antonio Mastropaolo, Denys Poshyvanyk, and Gabriele Bavota. 2025. On the Effectiveness of LLM-as-a-Judge for Code Generation and Summarization. *IEEE Transactions on Software Engineering (TSE)* 51, 8 (2025), 2329–2345. [doi:10.1109/TSE.2025.3586082](#)
- [5] DeepSeek-AI, Daya Guo, Dejian Yang, Haowei Zhang, Junxiao Song, Ruoyu Zhang, Runxin Xu, Qihao Zhu, Shirong Ma, Peiyi Wang, et al. 2025. *DeepSeek-R1: Incentivizing Reasoning Capability in LLMs via Reinforcement Learning*. [arXiv:2501.12948](#)
- [6] DeepSeek-AI, Aixin Liu, Bei Feng, Bing Xue, Bingxuan Wang, Bochao Wu, Chengda Lu, Chenggang Zhao, Chengqi Deng, Chenyu Zhang, et al. 2025. *DeepSeek-V3 Technical Report*. [arXiv:2412.19437](#)
- [7] Yangruibo Ding, Yanjun Fu, Omniyyah Ibrahim, Chawin Sitawarin, Xinyun Chen, Basel Alomair, David Wagner, Baishakhi Ray, and Yizheng Chen. 2025. Vulnerability Detection with Code Language Models: How Far are We?. In *International Conference on Software Engineering (ICSE)*. IEEE/ACM, Ottawa, Ontario, Canada, 1729–1741. [doi:10.1109/ICSE55347.2025.00038](#)
- [8] Xueying Du, Geng Zheng, Kaixin Wang, Yi Zou, Yujia Wang, Wentai Deng, Jiayi Feng, Mingwei Liu, Bihuan Chen, Xin Peng, Tao Ma, and Yiling Lou. 2025. *Vul-RAG: Enhancing LLM-based Vulnerability Detection via Knowledge-level RAG*. [arXiv:2406.11147](#)
- [9] Shahul Es, Jithin James, Luis Espinosa Anke, and Steven Schockaert. 2024. RAGAs: Automated Evaluation of Retrieval Augmented Generation. In *Conference of the European Chapter of the Association for Computational Linguistics: System Demonstrations*. ACL, St. Julians, Malta, 150–158. [doi:10.18653/v1/2024.eacl-demo.16](#)
- [10] Jiahao Fan, Yi Li, Shaohua Wang, and Tien N. Nguyen. 2020. A C/C++ Code Vulnerability Dataset with Code Changes and CVE Summaries. In *International Conference on Mining Software Repositories (MSR)*. ACM, Seoul, South Korea, 508–512. [doi:10.1145/3379597.3387501](#)
- [11] Aoran Gan, Hao Yu, Kai Zhang, Qi Liu, Wenyu Yan, Zhenya Huang, Shiwei Tong, and Guoping Hu. 2025. *Retrieval Augmented Generation Evaluation in the Era of Large Language Models: A Comprehensive Survey*. [arXiv:2504.14891](#)
- [12] Aaron Grattafiori, Abhimanyu Dubey, Abhinav Jauhri, Abhinav Pandey, Abhishek Kadian, Ahmad Al-Dahle, Aiesha Letman, Akhil Mathur, Alan Schelten, Alex Vaughan, et al. 2024. *The Llama 3 Herd of Models*. [arXiv:2407.21783](#)
- [13] Yuejun Guo and Seifeddine Bettaiieb. 2023. An Investigation of Quality Issues in Vulnerability Detection Datasets. In *European Symposium on Security and Privacy Workshops (EuroS&PW)*. IEEE, Delft, Netherlands, 29–33. [doi:10.1109/EuroSPW59978.2023.00008](#)
- [14] HS Esslingen IT Security. 2026. *Awesome LLM4SVD: LLM4SVD TAXONOMY*. <https://github.com/hs-esslingen-it-security/Awesome-LLM4SVD/tree/main/taxonomy>
- [15] Binyuan Hui, Jian Yang, Zeyu Cui, Jiayi Yang, Dayiheng Liu, Lei Zhang, Tianyu Liu, Jiajun Zhang, Bowen Yu, Keming Lu, et al. 2024. *Qwen2.5-Coder Technical Report*. [arXiv:2409.12186](#)
- [16] Albert Q. Jiang, Alexandre Sablayrolles, Arthur Mensch, Chris Bamford, Devendra Singh Chaplot, Diego de las Casas, Florian Bressand, Gianna Lengyel, Guillaume Lample, Lucile Saulnier, et al. 2023. *Mistral 7B*. [arXiv:2310.06825](#)
- [17] Sabrina Kaniewski, Fabian Schmidt, Markus Enzweiler, Michael Menth, and Tobias Heer. 2026. A Systematic Literature Review on Detecting Software Vulnerabilities with Large Language Models. *ACM Transactions on Software Engineering and Methodology (TOSEM)* (2026). Just Accepted. [doi:10.1145/3815425](#)
- [18] Sabrina Kaniewski, Fabian Schmidt, and Tobias Heer. 2026. Revisiting Vul-RAG: Reproducibility and Replicability of RAG-Based Vulnerability Detection With Open-Weight Models. In *Availability, Reliability and Security. ARES 2026 International Workshops: ARES 2026 International Workshops*. Springer, Linköping, Sweden, 76–95. [doi:10.1007/978-3-032-35576-8_5](#)
- [19] Qiang Ke, Yanjie Zhao, Hongjin Leng, Shengming Zhao, and Haoyu Wang. 2026. Not All RAGs Are Created Equal: A Component-Wise Empirical Study for Software Engineering Tasks. *Proceedings of the ACM on Software Engineering* 3, FSE, Article FSE183 (2026), 23 pages. [doi:10.1145/3808190](#)
- [20] Patrick Lewis, Ethan Perez, Aleksandra Piktus, Fabio Petroni, Vladimir Karpukhin, Naman Goyal, Heinrich Küttler, Mike Lewis, Wen-tau Yih, Tim Rocktäschel, et al. 2020. Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks. In *Advances in Neural Information Processing Systems (NeurIPS)*, Vol. 33. Curran Associates, Inc., Virtual-only, 9459–9474.
- [21] Youpeng Li, Fuxun Yu, and Xinda Wang. 2026. *From SFT to RL: Demystifying the Post-Training Pipeline for LLM-based Vulnerability Detection*. [arXiv:2602.14012](#)
- [22] Guilong Lu, Xiaolin Ju, Xiang Chen, Wenlong Pei, and Zhilong Cai. 2024. GRACE: Empowering LLM-based Software Vulnerability Detection with Graph Structure and In-Context Learning. *Journal of Systems and Software (JSS)* 212, C (2024), 112031. [doi:10.1016/j.jss.2024.112031](#)
- [23] Microsoft, Abdelrahman Abouelenin, Atabak Ashfaq, Adam Atkinson, Hany Awadalla, Nguyen Bach, Jianmin Bao, Alon Benhaim, Martin Cai, Vishrav Chaudhary, et al. 2025. *Phi-4-Mini Technical Report: Compact yet Powerful Multimodal*

- Language Models via Mixture-of-LoRAs*. arXiv:2503.01743
- [24] Yu Nong, Rainy Sharma, Abdelwahab Hamou-Lhadj, Xiapu Luo, and Haipeng Cai. 2023. Open Science in Software Engineering: A Study on Deep Learning-Based Vulnerability Detection. *IEEE Transactions on Software Engineering* 49, 4 (2023), 1983–2005. doi:10.1109/TSE.2022.3207149
 - [25] OpenAI, Josh Achiam, Steven Adler, Sandhini Agarwal, Lama Ahmad, Ilge Akkaya, Florencia Leoni Aleman, Diogo Almeida, Janko Altschmidt, Sam Altman, et al. 2024. *GPT-4 Technical Report*. arXiv:2303.08774
 - [26] OpenAI, Sandhini Agarwal, Lama Ahmad, Jason Ai, Sam Altman, Andy Applebaum, Edwin Arbus, Rahul K. Arora, Yu Bai, Bowen Baker, et al. 2025. gpt-oss-120b & gpt-oss-20b Model Card. arXiv:2508.10925
 - [27] Dyna Soumhane Ouchebara and Stéphane Dupont. 2025. Llama-Based Source Code Vulnerability Detection: Prompt Engineering vs Fine Tuning. In *European Symposium on Research in Computer Security (ESORICS)*. Springer, Toulouse, France, 289–308. doi:10.1007/978-3-032-07884-1_15
 - [28] Qwen. 2025. QwQ-32B: Embracing the Power of Reinforcement Learning. <https://qwen.ai/blog?id=qwq-32b>. Accessed 2026-09-11.
 - [29] Qwen. 2026. Qwen3.5: Towards Native Multimodal Agents. <https://qwen.ai/blog?id=qwen3.5>. Accessed 2026-09-11.
 - [30] Qwen. 2026. Qwen3.6-27B: Flagship-Level Coding in a 27B Dense Model. <https://qwen.ai/blog?id=qwen3.6-27b>. Accessed 2026-09-11.
 - [31] Qwen, An Yang, Baosong Yang, Beichen Zhang, Binyuan Hui, Bo Zheng, Bowen Yu, Chengyuan Li, Dayiheng Liu, Fei Huang, et al. 2025. *Qwen2.5 Technical Report*. arXiv:2412.15115
 - [32] Jon Saad-Falcon, Omar Khattab, Christopher Potts, and Matei Zaharia. 2024. ARES: An Automated Evaluation Framework for Retrieval-Augmented Generation Systems. In *Conference of the North American Chapter of the Association for Computational Linguistics: Human Language Technologies*. ACL, Mexico City, Mexico, 338–354. doi:10.18653/v1/2024.naacl-long.20
 - [33] June Sallou, Thomas Durieux, and Annibale Panichella. 2024. Breaking the Silence: the Threats of Using LLMs in Software Engineering. In *ACM/IEEE International Conference on Software Engineering: New Ideas and Emerging Results (ICSE-NIER)*. IEEE/ACM, Lisbon, Portugal, 102–106. doi:10.1145/3639476.3639764
 - [34] Hwanjun Song, Hang Su, Igor Shalyminov, Jason Cai, and Saab Mansour. 2024. FineSurE: Fine-grained Summarization Evaluation using LLMs. In *Annual Meeting of the Association for Computational Linguistics*. ACL, Bangkok, Thailand, 906–922. doi:10.18653/v1/2024.acl-long.51
 - [35] Benjamin Steenhoeck, Md Mahbubur Rahman, Monoshi Kumar Roy, Mirza Sanjida Alam, Hengbo Tong, Swarna Das, Earl T. Barr, and Wei Le. 2025. *To Err is Machine: Vulnerability Detection Challenges LLM Reasoning*. arXiv:2403.17218
 - [36] Weisong Sun, Yun Miao, Yuekang Li, Hongyu Zhang, Chunrong Fang, Yi Liu, Gelei Deng, Yang Liu, and Zhenyu Chen. 2025. Source Code Summarization in the Era of Large Language Models. In *IEEE/ACM International Conference on Software Engineering (ICSE)*. IEEE, Ottawa, ON, Canada, 1882–1894. doi:10.1109/ICSE55347.2025.00034
 - [37] Yuqiang Sun, Daoyuan Wu, Yue Xue, Han Liu, Wei Ma, Lyuye Zhang, Yang Liu, and Yingjiu Li. 2025. *LLM4Vuln: A Unified Evaluation Framework for Decoupling and Enhancing LLMs' Vulnerability Reasoning*. arXiv:2401.16185
 - [38] Karl Tamberg and Hayretin Bahsi. 2025. Harnessing Large Language Models for Software Vulnerability Detection: A Comprehensive Benchmarking Study. *IEEE Access* 13 (2025), 29698–29717. doi:10.1109/ACCESS.2025.3541146
 - [39] Wenxin Tang, Xiang Zhang, Junliang Liu, Jingyu Xiao, Xi Xiao, Jinlong Yang, Yuehe Ma, Zhenyu Liu, Zhengheng Li, Zicheng Wang, Wang Luo, Qing Li, Lei Wang, and Peng Xiangli. 2026. *VulTriage: Triple-Path Context Augmentation for LLM-Based Vulnerability Detection*. arXiv:2605.09461
 - [40] Gemma Team, Aishwarya Kamath, Johan Ferret, Shreya Pathak, Nino Vieillard, Ramona Merhej, Sarah Perrin, Tatiana Matejovicova, Alexandre Ramé, Morgane Rivière, et al. 2025. *Gemma 3 Technical Report*. arXiv:2503.19786
 - [41] Saad Ullah, Mingji Han, Saurabh Pujar, Hammond Pearce, Ayse Coskun, and Gianluca Stringhini. 2024. LLMs Cannot Reliably Identify and Reason About Security Vulnerabilities (Yet?): A Comprehensive Evaluation, Framework, and Benchmarks. In *Symposium on Security and Privacy (SP)*. IEEE, San Francisco, CA, USA, 862–880. doi:10.1109/SP54263.2024.00210
 - [42] Ruiqi Wang, Jiyu Guo, Cuiyun Gao, Guodong Fan, Chun Yong Chong, and Xin Xia. 2025. Can LLMs Replace Human Evaluators? An Empirical Study of LLM-as-a-Judge in Software Engineering. *Proceedings of the ACM on Software Engineering (PACMSE)* 2, ISSTA, Article ISSTA086 (June 2025), 23 pages. doi:10.1145/3728963
 - [43] Yang Wu, Yao Wan, Zhaoyang Chu, Wenting Zhao, Ye Liu, Hongyu Zhang, Xuanhua Shi, Hai Jin, and Philip S. Yu. 2025. Can Large Language Models Serve as Evaluators for Code Summarization? *IEEE Transactions on Software Engineering (TSE)* 51, 12 (2025), 3205–3217. doi:10.1109/TSE.2025.3595283
 - [44] An Yang, Anfeng Li, Baosong Yang, Beichen Zhang, Binyuan Hui, Bo Zheng, Bowen Yu, Chang Gao, Chengen Huang, Chenxu Lv, et al. 2025. *Qwen3 Technical Report*. arXiv:2505.09388
 - [45] Ting Zhang, Chengran Yang, Yindu Su, Martin Weyssow, Hung Nguyen, Tan Bui, Hong Jin Kang, Yikun Li, Eng Lieh Ouh, Lwin Khin Shar, and David Lo. 2025. *Benchmarking Large Language Models for Multi-Language Software Vulnerability Detection*. arXiv:2503.01449

- [46] Tiancheng Zhao, Chao Ma, Luogang Zhang, Jinbo Yang, and Lili Nie. 2026. Retrieval-Augmented Semantic Mapping for Vulnerability Detection via Multi-View Code Similarity. *Electronics* 15, 3 (2026). doi:10.3390/electronics15030612
- [47] Hao Zhu, Jia Li, Cuiyun Gao, Jiaru Qian, Yihong Dong, Huanyu Liu, Lecheng Wang, Ziliang Wang, Xiaolong Hu, and Ge Li. 2026. VullInstruct: Teaching LLMs Root-Cause Reasoning for Vulnerability Detection via Security Specifications. *Proceedings of the ACM on Software Engineering* 3, FSE, Article FSE125 (2026), 22 pages. doi:10.1145/3808132